



UNIDAD 4

SEGURIDAD

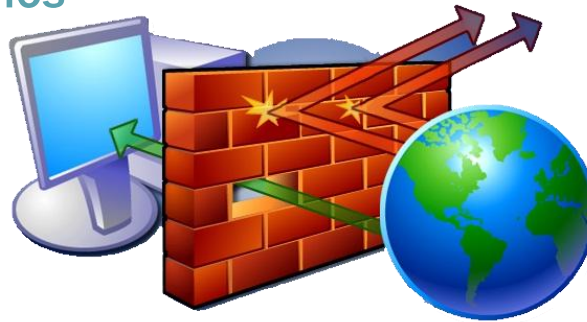


Sistemas Operativos II

Seguridad

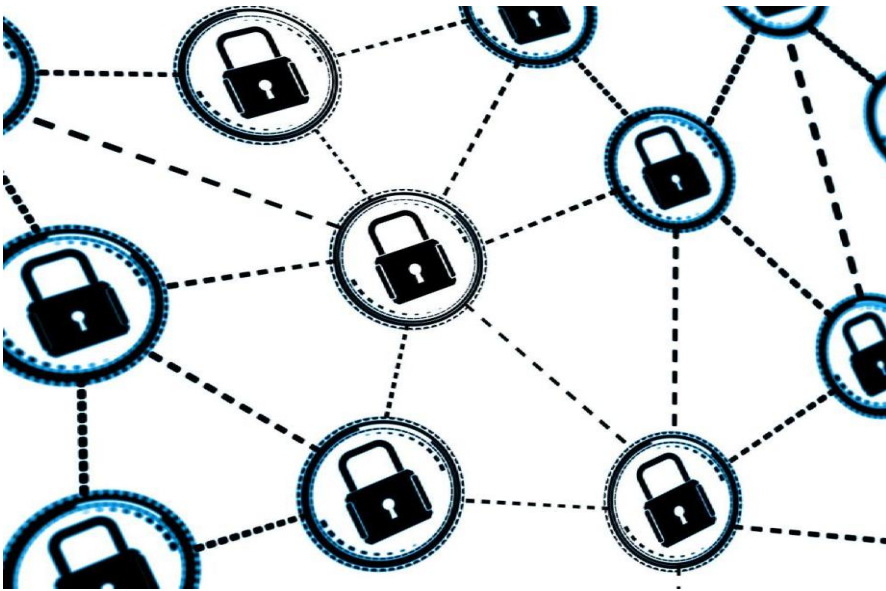
☞ Seguridad

- Amenazas
- Autenticación de usuarios
- Criptografía
- Defensa
- Cortafuegos
- Seguridad en Linux



Seguridad

Principios de la Seguridad



Confidencialidad

Garantiza que la información solo sea accesible por personas autorizadas usando cifrado y autenticación.

Integridad

Asegura que los datos no sean alterados sin autorización mediante firmas digitales y funciones hash.

Disponibilidad

Mantiene los sistemas accesibles protegiéndolos contra fallas y ataques como denegación de servicio.

Seguridad

∞ En un sistema seguro los recursos son

- utilizados de la forma prevista
- accedidos de la forma correcta.

∞ Las violaciones de seguridad se clasifican en:

- Intencionadas (maliciosas)
- Accidentales

Amenazas, ataques y malware



Amenaza

- Posibilidad de violación de seguridad

Ataque

- Intento de romper la seguridad



Intruso

Cracker

Intrusos

☞ Aquellos que se meten donde no les incumbe.

☞ Pueden ser:

- Pasivos: solo quieren leer archivos que no están autorizados para leer
- Activos: quieren hacer cambios no autorizados a los datos.



Intrusos

∞ En el diseño de un sistema seguro contra intrusos, tener en cuenta:

💀 El tipo de intruso

🔒 La cantidad de esfuerzo para lograr la seguridad y la protección en función de quien se considera sea el intruso



Intrusos: Categorías

☞ Convencionales

- Curiosidad casual de usuarios no técnicos
- Husmeo por parte de personal interno
- Intentos decididos por hacer dinero
- Espionaje comercial o militar



☞ No convencional

- Malware



Metas y Amenazas

Metas

Confidencialidad de los datos

Integridad de los datos

Disponibilidad del sistema

Autenticación del usuario

Amenazas

Revelación de los datos

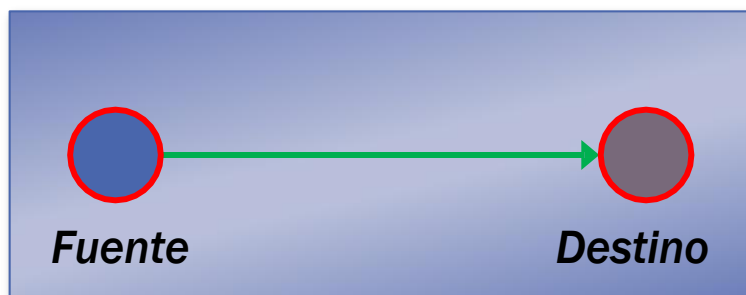
Alteración de los datos

Negación del servicio

Robo de identidad

Tipos de Ataque

- ∞ En una comunicación hay un flujo de información desde una fuente hacia un destino remoto, que está expuesta a 4 categorías de ataque, como:



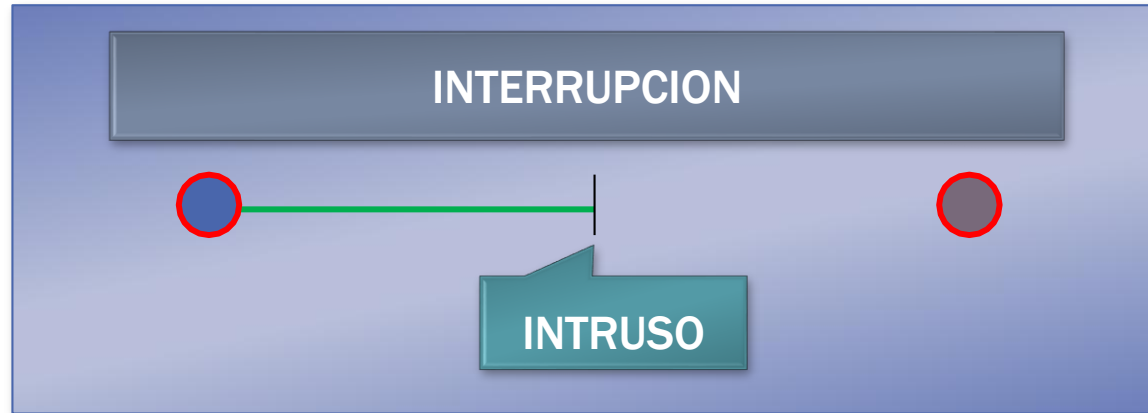
Interrupción

Intercepción

Modificación

Fabricación

Ataques De Interrupción

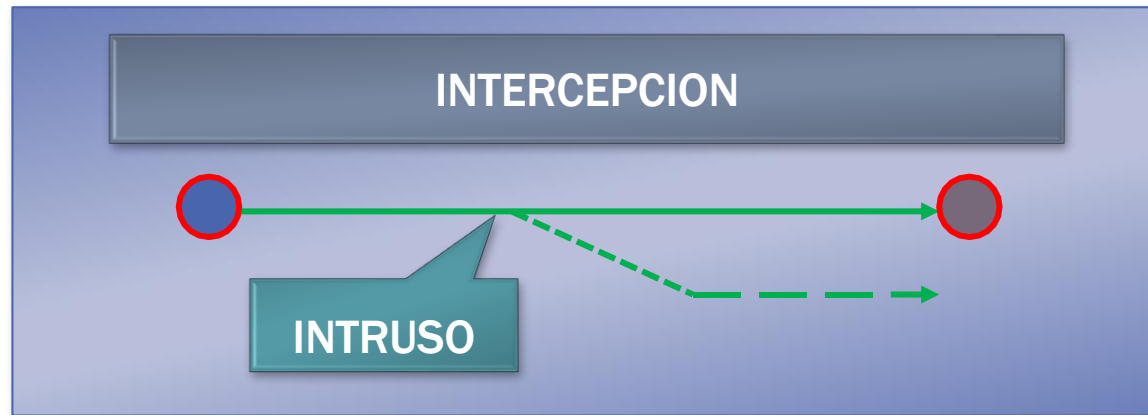


- Se daña, pierde o deja de funcionar un punto del sistema
- Su detección es inmediata

- Ejemplos:
 - Destrucción del disco duro
 - Borrado de programas o datos
 - Corte de una línea de comunicación



Ataques De Intercepción

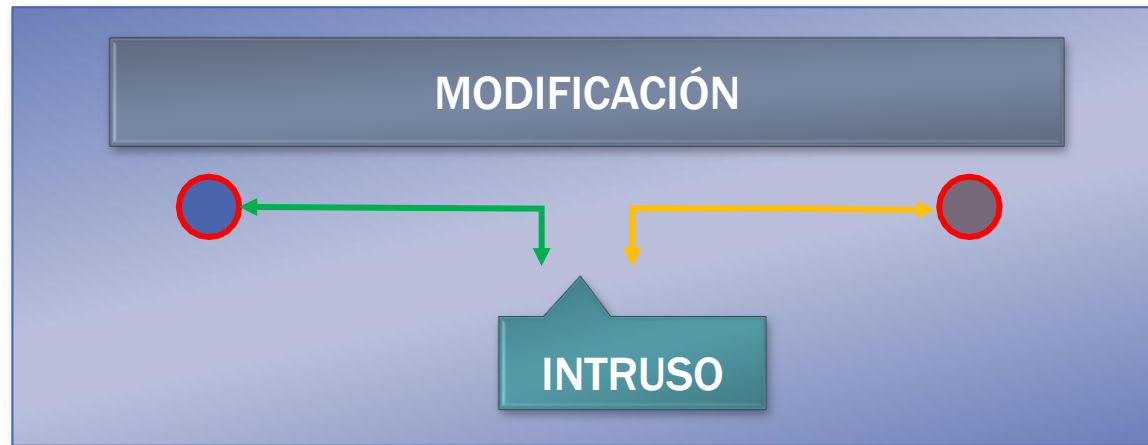


- Acceso a la información por parte de personas no autorizadas. Uso de privilegios no adquiridos
- Su detección es difícil, a veces no deja huellas

- Ejemplos:
 - Copias ilícitas de programas
 - Escucha en línea de datos



Ataques De Modificación



- Acceso no autorizado que cambia la información para su beneficio
- Su detección es difícil, según las circunstancias

- Ejemplos:
 - Modificación de bases de datos
 - Modificación de mensajes transmitidos en una red



Ataques De Fabricación



- Creación de nuevos objetos dentro del sistema
- Su detección es difícil: delitos de falsificación

- Ejemplos:
 - Introducción de mensajes falsos en una red
 - Añadir registros en bases de datos



Malware clásico y moderno

Tipos clásicos de malware

Virus, gusanos y troyanos son ejemplos de malware clásico que explotan vulnerabilidades para infectar sistemas.

Malware moderno: ransomware

El ransomware afecta confidencialidad, integridad y disponibilidad, con gran impacto económico y social.



Malware



Virus

- Ejemplo: El histórico virus ILOVEYOU, que se propagaba vía email y sobrescribía archivos personales.

2. Gusanos (Worms)

- Ejemplo: Stuxnet, diseñado para atacar sistemas de control industrial.

3. Ransomware

- Ejemplo: WannaCry, que en 2017 afectó a miles de organizaciones a nivel mundial, incluyendo sistemas de salud y telecomunicaciones.

4. Troyanos (Trojans)

- Ejemplo: Emotet, que comenzó como un troyano bancario y evolucionó para distribuir otros tipos de malware.

5. Spyware

- Ejemplo: Pegasus, un software de vigilancia de alto nivel capaz de extraer mensajes y activar cámaras en teléfonos móviles.

Modelo de un Virus

Un virus responde al modelo DAS.

Dañino

Autorreplicante

Subrepticio

Clasificación de los Virus

Virus Parásito

- Tradicional y habitual. Se inserta dentro de ficheros ejecutables

Virus residente en memoria

- Infecta la MP

Virus en el sector de arranque

- Infecta el sector de arranque

Virus oculto

- Diseñado para esconderse de la detección de los antivirus

Virus polimórfico

- Muta con cada infección haciendo que la detección sea imposible

Virus basado en macros

- Infectan documentos

Modelo de virus informático

Módulo de reproducción

- se encarga de manejar las rutinas de "parasitación" de entidades ejecutables (o archivos de datos, en el caso de los virus macro) a fin de que el virus pueda ejecutarse subrepticamente

Módulo de ataque (optativo)

- es el encargado de manejar las rutinas de daño adicional del virus

Módulo de defensa (optativo)

- su función apunta a evitar todo aquello que provoque la remoción del virus y retardar, en todo lo posible, su detección

Autenticación, criptografía y mecanismos del sistema operativo





Autenticación de Usuario



CONOCE – TIENE – ES

Autenticación de Usuario

∞ El SO quiere determinar quién es el usuario que utilizará la computadora

¿Como llevarla a cabo?

- ∞ Teniendo en cuenta alguno de los 3 principios. generales:
- Algo que CONOCE el usuario (id y contraseña)
 - Algo que TIENE el usuario (clave o tarjeta)
 - Algo que ES el usuario (biométrica)

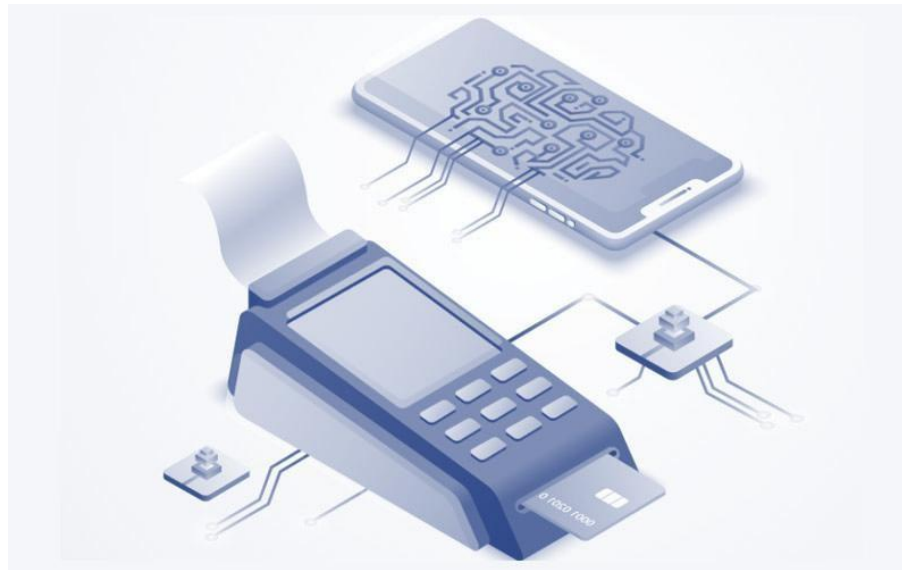
CONOCE: Contraseña

- Fácil de entender e implementar
- La implementación más sencilla mantiene una lista central de pares (*inicio de sesión, contraseña*).



TIENE: objeto físico

- Se utiliza una tarjeta de plástico que se inserta en un lector enlazado con la terminal o computadora. Generalmente además de la tarjeta el usuario debe teclear una clave.



TIENE: objeto físico

Las tarjetas pueden ser de dos tipos:

- Tarjetas con franja magnética.
- Tarjetas con chip



ES: biometría

- ∞ Este método mide características físicas del usuario que son difíciles de falsificar (*huellas dactilares, patrón de voz, etc.*).
- ∞ Consta de dos partes:
 - Inscripción
 - Identificación



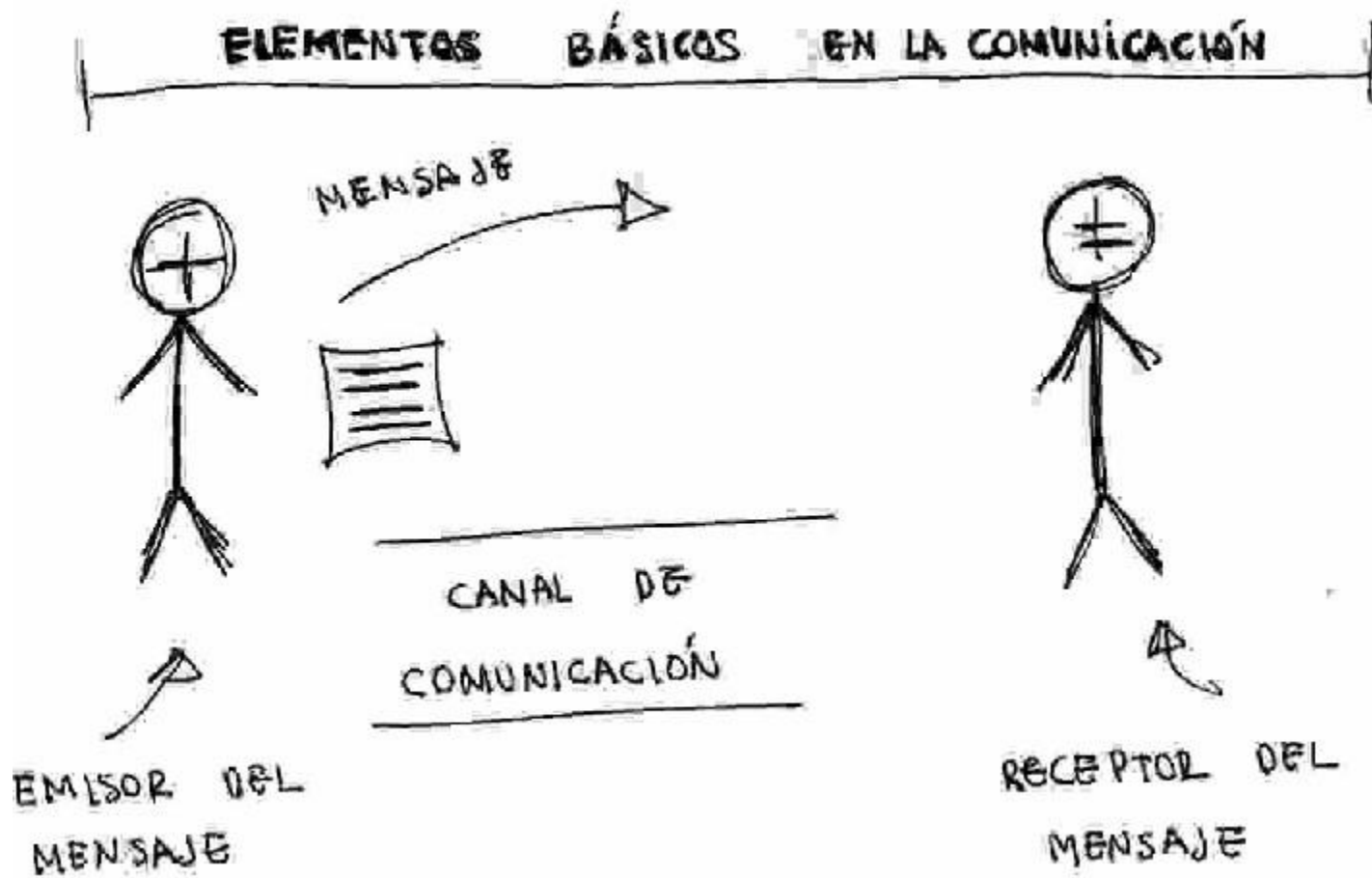


CRIPTOGRAFIA



Escritura Oculta

Comunicación



Criptografía: Definición

- ∞ Arte o ciencia de cifrar y descifrar información.
- ∞ Del griego “kriptos” (ocultar) y “graphos” (escribir), literalmente “escritura oculta”.
- ∞ Se emplea para el *intercambio* de mensajes de manera segura.

Criptografía

ELEMENTOS BÁSICOS DE LA CRIPTOGRAFÍA



Criptografía: Cifrado

∞ Algoritmo

∞ Se requiere:

- Un conjunto K de claves
- Un conjunto M de mensajes
- Un conjunto C de mensajes de texto cifrado
- Una función de cifrado/encryptado

$$E: K \rightarrow (M \rightarrow C)$$

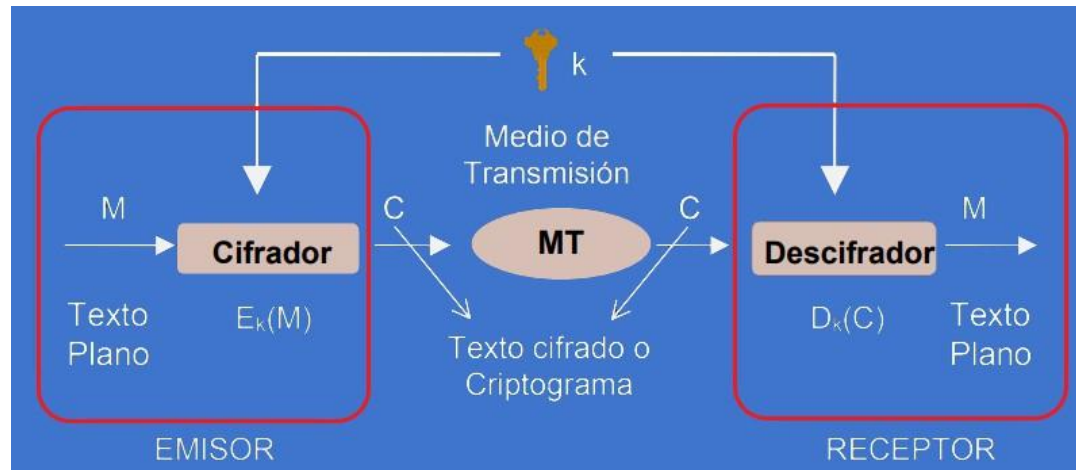
- Una función de descifrado/desencryptado

$$D: K \rightarrow (C \rightarrow M)$$

Criptografía: Tipos de Algoritmos

∞ Simétricos

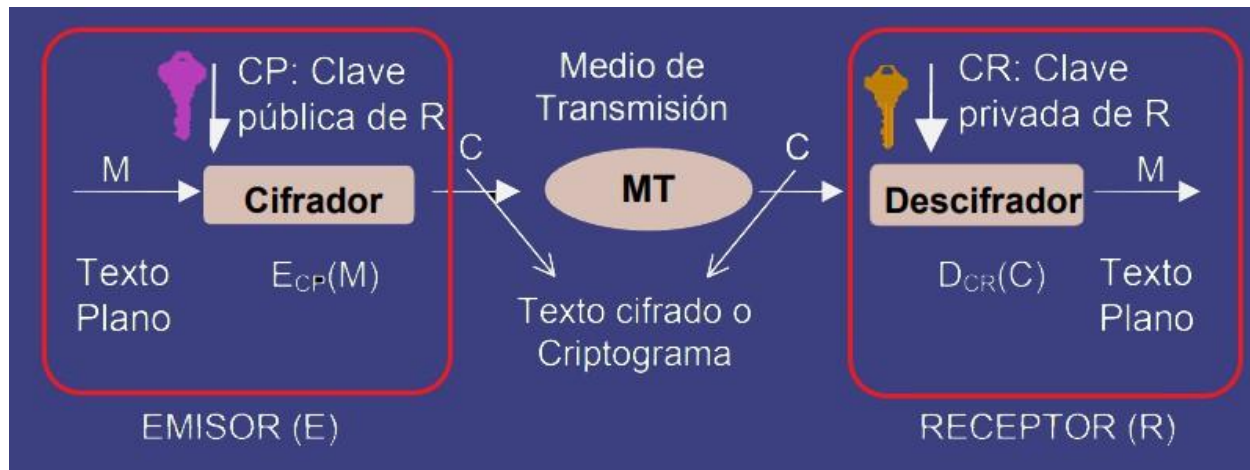
- La misma clave para cifrar y descifrar
- Las dos partes que se comunican han de acordar de antemano sobre la clave a usar.
- Un buen sistema de cifrado pone toda la seguridad en la clave y ninguna en el algoritmo:
 - la clave debe ser muy difícil adivinar
 - Importante: longitud de la clave y conjunto de caracteres que emplee
- Ejemplos clásicos:
 - DES: bloques de 64 bits . Claves de 56 bits. Sustitución/Permutación
 - Triple DES: se repite 3 veces DES (dos cifrados y un descifrado) y 2 o 3 claves. 3 Claves de 168 bits
 - AES: claves de 128, 192 y 256 bits y bloques de 128 bits.



Criptografía: Tipos de Algoritmos

Asimétricos

- Las claves de cifrado y descifrado son distintas
- Lo que se cifra en emisión con una clave, se descifra en recepción con la clave inversa.
- La seguridad del sistema reside en la dificultad computacional de descubrir la clave privada a partir de la pública. Para ello, se usan funciones matemáticas de un solo sentido.
- Ejemplos. Diffie-Hellman, RSA, DSA



Criptografía: Algoritmo Asimétrico

∞ RSA:

- Maneja una clave pública ($E(k_e, N)$) y una clave privada ($D(k_d, N)$). N es el producto de dos números primos de gran magnitud p y q .

- El algoritmo de cifrado es

$$E(k_e, N)(m) = m^{k_e} \bmod N$$

- tal que k_e satisface la ecuación $k_e k_d \bmod (p-1)(q-1) = 1$

- El algoritmo de descifrado es

$$D(k_d, N)(c) = c^{k_d} \bmod N$$

Criptografía

∞ RSA: Ejemplo

- Sean $p=7$, $q=13$
- $N=91$
- $(p-1)(q-1)=72$
- k_e (relativamente prima a 72 y <72) $\rightarrow 5$
- $k_d = 29$ (puesto que $(5 \cdot 29) \bmod 72 = 1$)

∞ Mensaje Plano $m= 69$

∞ Cifrado: $E(k_e, N)(m) = m^{k_e} \bmod N$

- $E(5, 91) = 69^5 \bmod 91 \rightarrow 62$

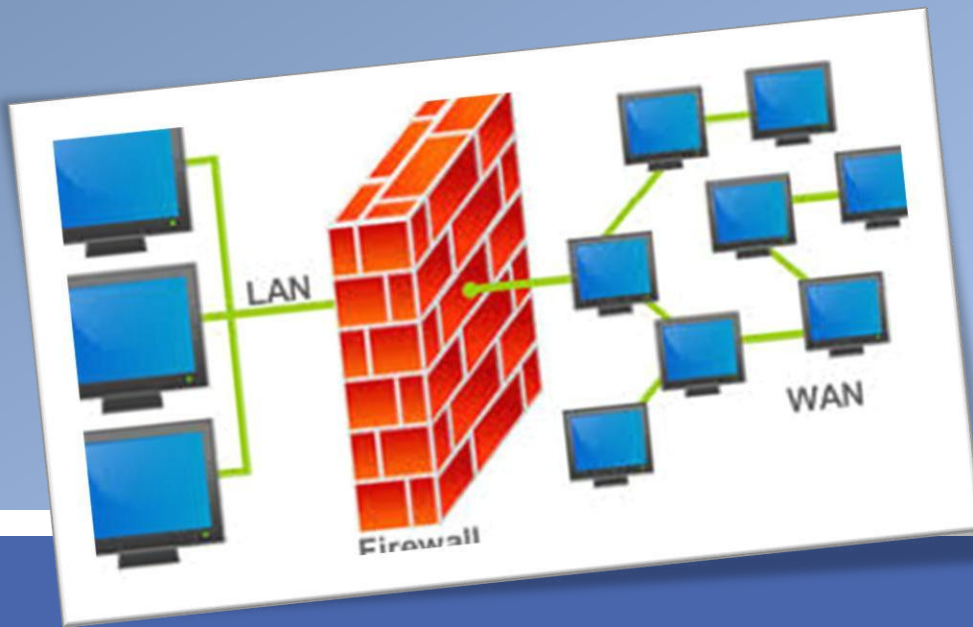
∞ Descifrado: $D(k_d, N)(c) = c^{k_d} \bmod N$

- $D(29, 91) = 62^{29} \bmod 91 \rightarrow 69$

Criptografía

Atributo	Clave simétrica	Clave asimétrica
Años en uso	Miles	Menos de 50
Velocidad	Rápida	Lenta
Uso principal	Cifrado de grandes volúmenes de datos	Intercambio de claves Firma digital
Claves	Compartidas entre emisor y receptor	Privada: sólo conocida por 1 persona. Pública: conocida por todos.
Intercambio de claves	Difícil de intercambiar por un canal inseguro	La clave pública se comparte por cualquier canal. La privada nunca se comparte
Longitud de claves	56 bits (vulnerable) 256 bits (seguro)	1024 bits mínimo
Algoritmos	DES, 3DES, Blowfish, IDEA, AES	Diffie-Hellman, RSA, DSA, ElGamal
Servicios de seguridad	Confidencialidad Integridad Autenticación	Confidencialidad Integridad Autenticación, No repudio

Defensas, firewalls y modelos de seguridad



Cortafuegos



Firewall

Cortafuegos

- ∞ Sistema de seguridad que bloquea accesos no autorizados a una computadora mientras sigue permitiendo la comunicación de la computadora con otros servicios autorizados.
- ∞ Se utilizan en redes de computadoras, especialmente en intranets o redes locales.

Cortafuegos

∞ Los cortafuegos pueden ser

- de software,
- de hardware o
- una combinación de ambos.

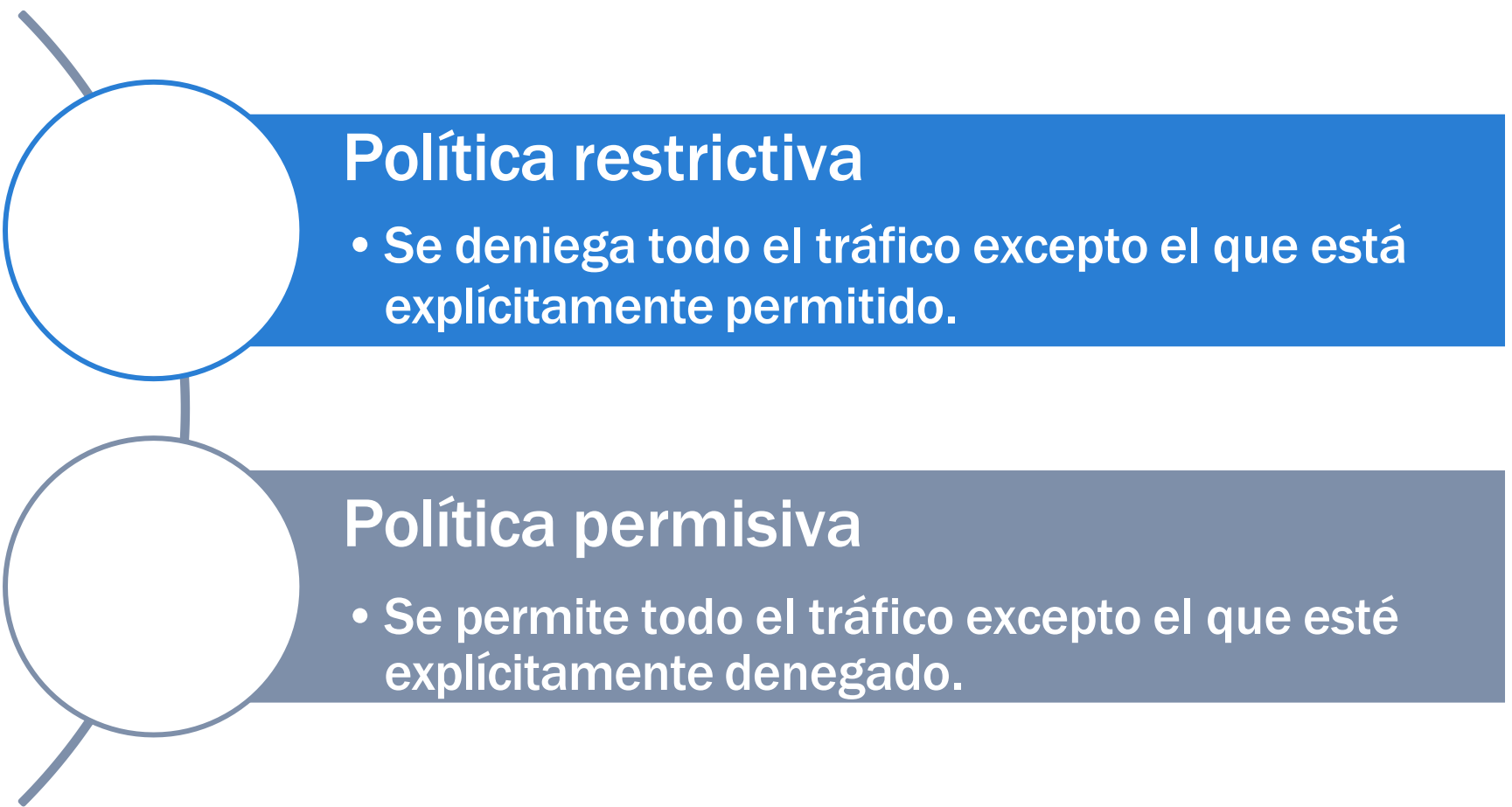


Cortafuegos: Limitaciones

∞ Los cortafuegos NO

- Eliminan el malware que intenta entrar, sólo trata de bloquear su acceso.
- Pueden proteger contra aquellos ataques cuyo tráfico no pase a través de él
- Pueden proteger de las amenazas por ataques internos o usuarios Negligentes
- Pueden proteger contra los ataques de ingeniería social.

Cortafuegos: Políticas



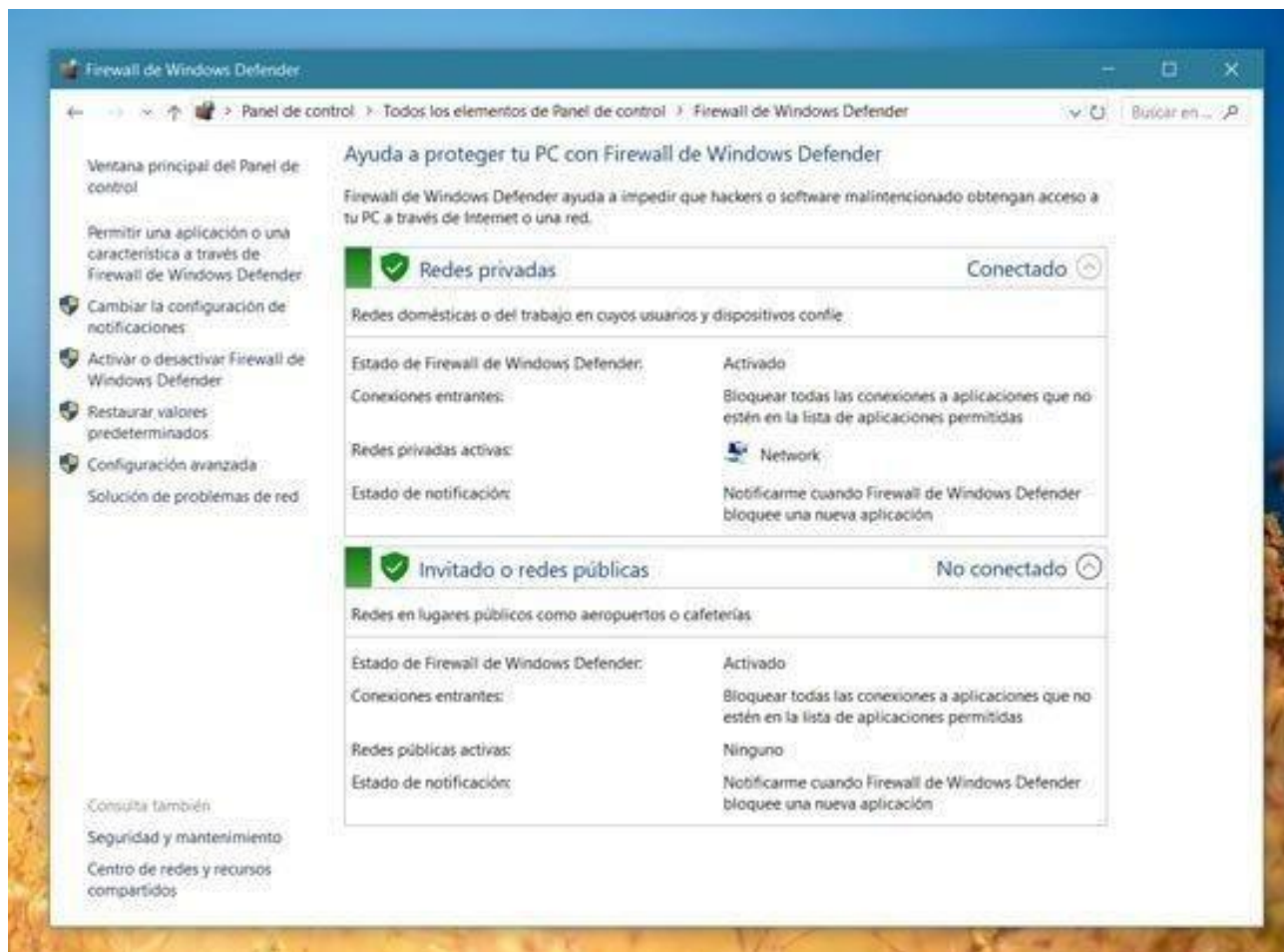
Política restrictiva

- Se deniega todo el tráfico excepto el que está explícitamente permitido.

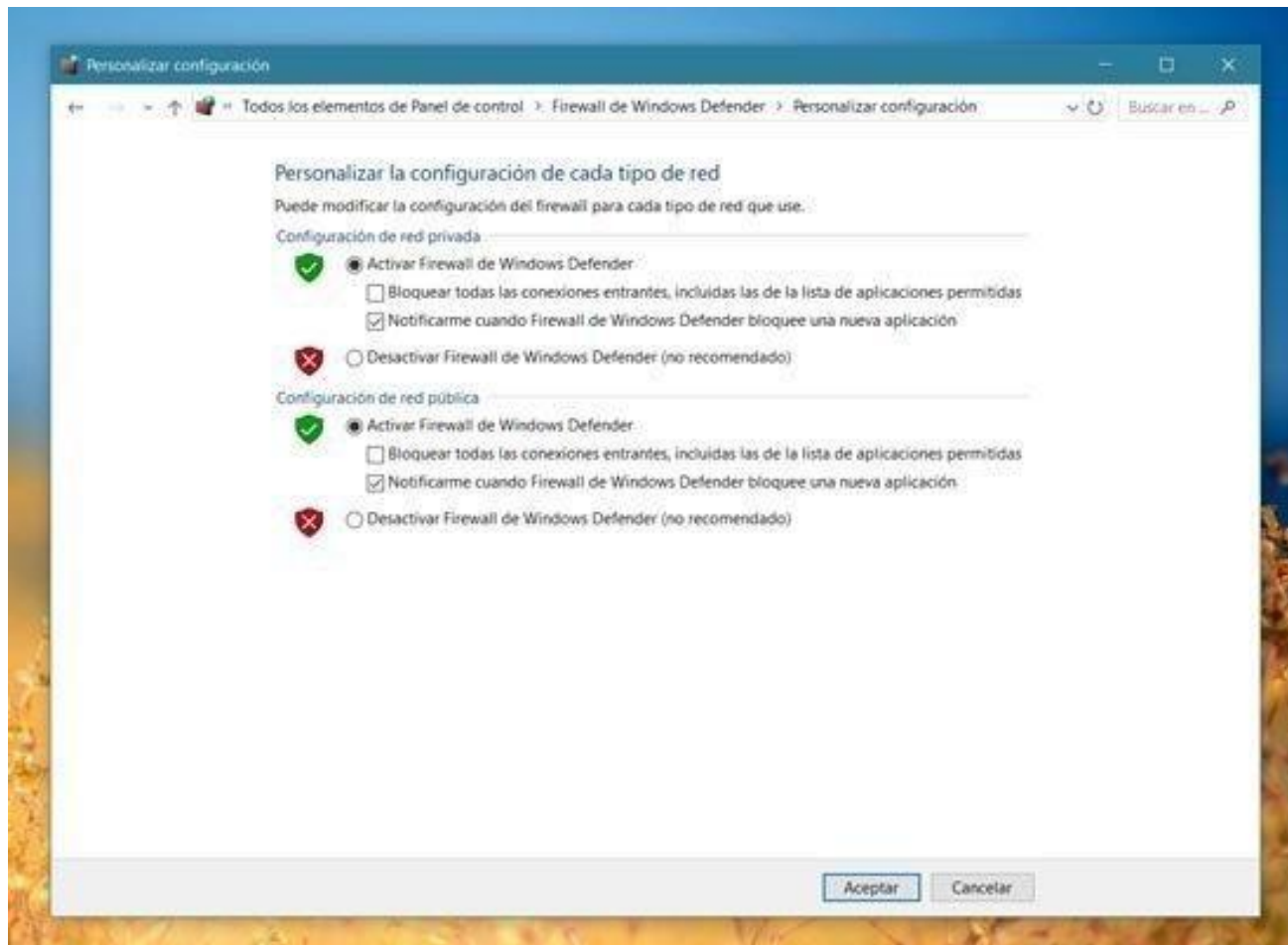
Política permisiva

- Se permite todo el tráfico excepto el que esté explícitamente denegado.

Firewall de Windows



Firewall de Windows





Seguridad en Linux



Seguridad en Linux



Objetivos

- Comprender el modelo de seguridad de Linux.
- Analizar UID, GID y permisos de acceso.
- Entender el funcionamiento de SETUID y SETGID.
- Identificar las llamadas al sistema relacionadas con la seguridad.

Seguridad en Linux



Linux fue diseñado como un sistema:

- ✓ Multiusuario
- ✓ Con control de acceso integrado
- ✓ Basado en propietarios y grupos

Elementos Principales

- UID (User ID): identificador único del usuario.
- GID (Group ID): identificador único del grupo.
- Los archivos, procesos y recursos poseen propietario y grupo.

Seguridad en Linux



Modelo de Protección en Linux

Cada archivo tiene permisos para tres categorías

Categoría	Significado
Usuario (Owner)	Propietario
Grupo (Group)	Miembros del grupo
Otros (Others)	Resto de usuarios

Permisos posibles:

r = lectura (read)

w = escritura (write)

x = ejecución (execute)

Total: 3 categorías × 3 permisos = 9 bits de protección

Seguridad en Linux



Modelo de Protección en Linux

Ejemplos de permisos de archivos

Simbólico	Significado
<code>rwx---</code>	El propietario puede hacer todo
<code>rw-rwx--</code>	Usuario y grupo tienen acceso total
<code>rw-r--r--</code>	Archivo público de lectura
<code>rw-r--r-x</code>	Programa ejecutable público
<code>-----</code>	Sin acceso para nadie

Ejemplo común:

`rw-r-xr-x`

Seguridad en Linux



El superusuario (root)

UID = 0

Características:

- Puede leer cualquier archivo.
- Puede modificar cualquier archivo.
- Puede ejecutar operaciones restringidas.
- Administra la seguridad del sistema.

Importancia: El usuario *root* posee privilegios que los usuarios comunes no tienen.

Seguridad en Linux



Permisos en Directorios

En directorios:

- **r** → listar contenido.
- **w** → crear o eliminar archivos.
- **x** → buscar o atravesar el directorio.

Ejemplo:

rwxr-xr-x

El propietario puede:

- Leer
- Modificar
- Buscar

Los demás:

- Leer
- Buscar

Pero no pueden agregar ni eliminar archivos

Seguridad en Linux



Bit SETUID

¿Qué problema resuelve?

Algunos programas necesitan privilegios especiales.

Ejemplo: **passwd**

Debe modificar el archivo de contraseñas. **/etc/shadow**

Solución

- Activar el bit **SETUID**

Cuando se ejecuta:

- El proceso adopta temporalmente el UID del propietario del programa.

Resultado:

- Un usuario normal puede ejecutar tareas privilegiadas de forma controlada.

SETUID vs UID Real

UID Real: Usuario que ejecutó el programa.

UID Efectivo: Usuario cuyos permisos se utilizan para verificar accesos.

Seguridad en Linux



Llamadas al sistema

Llamada	Función
chmod()	Cambia permisos
access()	Verifica accesos
getuid()	Obtiene UID real
geteuid()	Obtiene UID efectivo
getgid()	Obtiene GID real
getegid()	Obtiene GID efectivo
chown()	Cambia propietario
setuid()	Modifica UID
setgid()	Modifica GID

Seguridad en Linux



CHMOD

Comando:

```
chmod("/usr/ast/nuevojuego", 0755)
```

rwxr-xr-x

Interpretación:

- Propietario: lectura, escritura y ejecución.
- Grupo: lectura y ejecución.
- Otros: lectura y ejecución.

Sólo el propietario o root pueden cambiar estos permisos.

Permisos en Linux: CHMOD



Seguridad en Linux



Implementación de la Seguridad

Inicio de sesión

1. Usuario ingresa nombre y contraseña.
2. Linux aplica una función hash.
3. Se compara con la información almacenada.
4. Se obtienen **UID** y **GID**.
5. Se ejecuta el shell del usuario.
6. Los procesos hijos heredan esos identificadores.

Resultado: todo archivo creado queda asociado al usuario correcto.

